動的アプリケーションセキュリティテスト報告書

acme/app

不合格	6	1	0	3	2
	アラート	高	中	低	情報

対象

検査した URL	http://127.0.0.1:39823
サーバー	PHP の組み込みウェブサーバー（APP_ENV=test）
検査	OWASP ZAP：End-to-End テストのリクエストとレスポンスの確認と攻撃（最大 5 分）
End-to-End テスト	vendor/bin/phpunit --testsuite EndToEnd
ログイン	なし（訪問者として）
アラートのある URL	2
除外した URL	.*logout.*
不合格の基準	高以上

実行

実行日時	2026-10-19 12:41:50 〜 12:43:08（UTC）
所要時間	1分18秒
ソフトウェア	PHP 8.4.26　OWASP ZAP 2.17.0　pieceofcake2/security-dast 1.x-dev

フルスキャンは、攻撃者と同じようにスクリプトや SQL などでページとパラメーターを攻撃します。多くの脆弱性を見つけますが、クロールできなかったページのものなど、すべてではありません。

リスク別のアラート

1. 高

No.	アラート	リスク	リクエスト
1-1	クロスサイトスクリプティング (反射型)	高	1

2. 中

なし

3. 低

No.	アラート	リスク	リクエスト
3-1	SameSite属性のないCookie	低	2
3-2	X-Content-Type-Optionsヘッダーがありません	低	2
3-3	サーバーが "X-Powered-By" HTTPレスポンスヘッダーフィールド経由で情報を漏洩	低	3

4. 情報

No.	アラート	リスク	リクエスト
4-1	セッション管理レスポンスの特定	情報	1
4-2	ユーザーエージェントファザー (User Agent Fuzzer)	情報	3

確認した項目

確認した項目（問題なし）

ZAP のスキャンルールのうち、実行してサイトにアラートを出さなかったものです。

ルール ID	スキャンルール	スキャン
2	プライベートIPの露見	パッシブ
3	URLリライト内のセッションID	パッシブ
10003	脆弱なJSライブラリ (Retire.js による)	パッシブ
10009	ページ内バナー情報漏洩	パッシブ
10010	CookieにHttpOnlyフラグがない	パッシブ
10011	secureフラグのないCookie	パッシブ
10015	Cache-controlディレクティブを再確認する	パッシブ
10017	クロスドメインJavaScriptソースファイルのインクルージョン	パッシブ
10019	Content-Typeヘッダーがありません	パッシブ
10020	クリックジャッキング対策ヘッダー	パッシブ
10023	情報漏洩 - デバッグエラーメッセージ	パッシブ
10024	情報漏洩 - URL内の機密情報	パッシブ
10025	情報漏洩 - HTTP Referrerヘッダー内の機密情報	パッシブ
10027	情報漏洩 - 疑わしいコメント	パッシブ
10028	外部サイトへのリダイレクト	パッシブ
10029	Cookieポイズニング	パッシブ
10030	ユーザーが制御可能な文字コード	パッシブ
10031	ユーザーが制御可能なHTML要素属性 (XSSの可能性)	パッシブ
10032	Viewstate	パッシブ
10033	ディレクトリブラウジング	パッシブ
10034	Heartbleed OpenSSL の脆弱性 (指標)	パッシブ
10035	Strict-Transport-Securityヘッダー	パッシブ
10036	HTTPサーバーレスポンスヘッダー	パッシブ
10038	Content Security Policy (CSP) ヘッダーが設定されていない	パッシブ
10039	X-Backend-Server ヘッダーによる情報漏洩	パッシブ
10040	セキュアなページに混在コンテンツが含まれる	パッシブ
10041	フォーム送信におけるHTTPからHTTPSへの安全でない遷移	パッシブ
10042	フォーム送信におけるHTTPSからHTTPへの安全でない遷移	パッシブ

ルール ID	スキャンルール	スキャン
10043	ユーザーが制御可能なJavaScriptイベント (XSS)	パッシブ
10044	サイズの大きなリダイレクトを検出 (機密情報漏洩の可能性)	パッシブ
10050	キャッシュから取得	パッシブ
10052	X-ChromeLogger-Data (XCOLD) ヘッダーによる情報漏洩	パッシブ
10055	CSP	パッシブ
10056	X-Debug-Token ヘッダーによる情報漏洩	パッシブ
10057	ユーザー名ハッシュの検出	パッシブ
10061	X-AspNet-Version レスポンスヘッダー	パッシブ
10062	個人識別用情報の漏洩	パッシブ
10096	タイムスタンプの露見	パッシブ
10097	ハッシュの露見	パッシブ
10098	クロスドメイン設定ミス	パッシブ
10105	脆弱な認証方法	パッシブ
10108	リバース・タブナビング	パッシブ
10109	モダンWebアプリケーション	パッシブ
10111	認証リクエストが特定されました	パッシブ
10113	検証リクエストが特定されました	パッシブ
10115	悪意のあるドメインから配信されたスクリプト (polyfill)	パッシブ
10116	古いZAPバージョン	パッシブ
10202	Anti-CSRFトークンが使用されていない	パッシブ
50001	スクリプト パッシブスキャンルール	パッシブ
50003	統計 パッシブスキャンルール	パッシブ
90001	安全でないJSF ViewState	パッシブ
90002	Javaシリアル化オブジェクト	パッシブ
90003	サブリソース整合性属性の欠落	パッシブ
90011	文字セットの不一致	パッシブ
90022	アプリケーションエラーの露見	パッシブ
90030	WSDLファイル検出	パッシブ
90033	スコープが広いクッキー	パッシブ
0	ディレクトリブラウジング	アクティブ
6	パス・トラバーサル	アクティブ
7	リモート ファイル　インクルージョン	アクティブ

ルール ID	スキャンルール	スキャン
10045	ソースコードの露見 - /WEB-INF フォルダー	アクティブ
10047	HTTPSコンテンツがHTTP経由でアクセス可能	アクティブ
10048	リモートコード実行 - Shell Shock	アクティブ
10058	GET for POST	アクティブ
10106	HTTPのみのサイト	アクティブ
20015	Heartbleed OpenSSL の脆弱性	アクティブ
20017	ソースコードの露見 - CVE-2012-1823	アクティブ
20018	リモートコード実行 - CVE-2012-1823	アクティブ
20019	外部リダイレクト	アクティブ
30001	バッファ オーバーフロー	アクティブ
30002	書式文字列エラー	アクティブ
40003	CRLFインジェクション	アクティブ
40008	パラメーター改ざん	アクティブ
40009	サーバーサイドインクルード	アクティブ
40014	クロスサイトスクリプティング (格納型)	アクティブ
40016	クロスサイトスクリプティング (格納型) - Prime	アクティブ
40017	クロスサイトスクリプティング (格納型) - スパイダー	アクティブ
40018	SQL インジェクション	アクティブ
40019	SQLインジェクション - MySQL (時間ベース)	アクティブ
40020	SQLインジェクション - Hypersonic SQL (時間ベース)	アクティブ
40021	SQLインジェクション - Oracle (時間ベース)	アクティブ
40022	SQLインジェクション - PostgreSQL (時間ベース)	アクティブ
40026	クロス サイト スクリプティング (DOM ベース)	アクティブ
40027	SQLインジェクション - MsSQL (時間ベース)	アクティブ
40028	ELMAH からの情報漏洩	アクティブ
40029	Trace.axd 情報漏洩	アクティブ
40032	.htaccess からの情報漏洩	アクティブ
40034	.env からの情報漏洩	アクティブ
40035	隠しファイルファインダー	アクティブ
40042	Spring Actuator 情報漏洩	アクティブ
40044	指数関数的エンティティ展開（Billion Laughs攻撃）	アクティブ

ルール ID	スキャンルール	スキャン
40045	Spring4Shell	アクティブ
40048	リモートコード実行 (React2Shell)	アクティブ
50000	スクリプト アクティブスキャンルール	アクティブ
90017	XSLTインジェクション	アクティブ
90019	サーバーサイドコードインジェクション	アクティブ
90020	リモートOSコマンドインジェクション	アクティブ
90021	XPathインジェクション	アクティブ
90023	XML外部実体参照 (XXE) 攻撃	アクティブ
90024	一般パディングオラクル	アクティブ
90026	SOAP Action スプーフィング	アクティブ
90029	SOAP XML インジェクション	アクティブ
90034	クラウドメタデータが露呈する可能性	アクティブ
90035	サーバーサイドテンプレートインジェクション	アクティブ
90036	サーバーサイドテンプレートインジェクション (ブラインド)	アクティブ
90037	リモートOSコマンドインジェクション (時間ベース)	アクティブ
100043	Swagger UI Secret & Vulnerability Detector	アクティブ

実行しなかった項目

実行しなかったスキャンルールとその理由です。何も検査していないため、アラートは出ていません。

ルール ID	スキャンルール	スキャン	理由
40043	Log4Shell	アクティブ	ZAP が飛ばしました（サイトの技術に当てはまらない、攻撃するページがない、または制限時間）

1. 高

1-1　クロスサイトスクリプティング (反射型)

高

アラート ID	40012
リスク	高
確度	中
CWE	CWE-79
WASC	WASC-8
リクエスト	1

クロスサイトスクリプティング (XSS) は、攻撃者が提供したコードをユーザーのブラウザーインスタンスに反映 (echo) させる攻撃手法です。 ブラウザーインスタンスには、標準的なWebブラウザークライアントのほか、WinAmp内のブラウザ、RSSリーダー、メールクライアントなどのソフトウェア製品に埋め込まれたブラウザーオブジェクトも含まれます。 コード自体は通常HTML/JavaScriptで記述されますが、VBScript、ActiveX、Java、Flash、その他ブラウザーがサポートするあらゆる技術に及ぶ可能性があります。
攻撃者がユーザーのブラウザーに自身のコードを実行させると、そのコードはホスティングしているWebサイトのセキュリティコンテキスト (またはゾーン) 内で実行されます。 この権限レベルでは、コードはブラウザーがアクセス可能なあらゆる機密データの読み取り、変更、送信する能力を持ちます。 クロスサイトスクリプティングの被害を受けたユーザーは、アカウントを乗っ取られたり (Cookie窃取)、ブラウザーを別の場所にリダイレクトされたり、訪問しているWebサイトから配信される詐欺的なコンテンツを表示させられたりする可能性があります。 クロスサイトスクリプティング攻撃は本質的にユーザーとWebサイトとの間の信頼関係を侵害します。 ファイルシステムからコンテンツを読み込むブラウザーオブジェクトインスタンスを利用するアプリケーションはローカルマシンゾーン下でコードを実行する可能性があり、システムの侵害につながる可能性があります。

クロスサイトスクリプティング攻撃には、非永続的 (non-persistent)、永続的 (persistent)、DOMベースの3つのタイプがあります。
非永続的攻撃とDOMベース攻撃では、ユーザーは悪意のあるコードが仕込まれた特別に細工されたリンクを訪問するか、脆弱なサイトにPOSTすると攻撃を開始する悪意のあるWebフォームを含むWebページを訪問する必要があります。 悪意のあるフォームの使用は、脆弱なリソースがHTTP POSTリクエストのみを受け付ける場合によく行われます。 そのような場合、フォームは (例えばJavaScriptを使用して) 被害者の知らないうちに自動的に送信されることがあります。 悪意のあるリンクをクリックするか悪意のあるフォームを送信すると、XSSペイロードが反映されてユーザーのブラウザーによって解釈され、実行されます。 Adobe Flashのような埋め込みクライアントを使用することで、ほぼ任意のリクエスト (GETおよびPOST) を送信する手法もあります。
永続的攻撃は、悪意のあるコードがWebサイトに送信され、一定期間保存される場合に発生します。 攻撃者のお気に入りのターゲットの例には、メッセージボードの投稿、Webメールのメッセージ、Webチャットソフトウェアなどがよく含まれます。 疑いを持たないユーザーは、追加のサイト/リンク (例: 攻撃者のサイトやメールで送信された悪意のあるリンク) と対話する必要はなく、単にコードを含むWebページを表示するだけで被害に遭います。

対策

フェーズ: アーキテクチャおよび設計
この脆弱性の発生を許さない、あるいは回避を容易にする構造を備えた、十分に検証されたライブラリやフレームワークを使用してください。
適切にエンコードされた出力を生成しやすくするライブラリやフレームワークの例には、MicrosoftのAnti-XSSライブラリ、OWASP ESAPIのEncodingモジュール、Apache Wicketなどがあります。

フェーズ: 実装、アーキテクチャおよび設計
データが使用されるコンテキストと期待されるエンコーディングを理解してください。 これは、異なるコンポーネント間でデ

ータを転送する場合や、Webページやマルチパートメールメッセージのように複数のエンコーディングを同時に含む可能性のある出力を生成する場合に特に重要です。 期待されるすべての通信プロトコルとデータ表現を調査し、必要なエンコーディング戦略を決定してください。
別のWebページに出力されるデータ、特に外部入力から受け取ったデータについては、すべての非英数字に対して適切なエンコーディングを使用してください。
必要なエンコーディングとエスケープの種類の詳細については、XSS対策チートシートを参照してください。

フェーズ: アーキテクチャおよび設計
クライアント側で実行されるセキュリティチェックについては、CWE-602を回避するために、これらのチェックがサーバー側で複製されていることを確認してください。 攻撃者は、チェックが実行された後に値を変更したり、クライアントを変更してクライアント側のチェックを完全に削除したりすることで、クライアント側のチェックをバイパスできます。 その後、これらの変更された値がサーバーに送信されます。

利用可能であれば、データとコードの分離を自動的に強制する構造化されたメカニズムを使用してください。 これらのメカニズムは、開発者が出力を生成するすべての箇所でこの機能を提供することに頼るのではなく、関連するクォーティング、エンコーディング、および検証を自動的に提供できる場合があります。

フェーズ: 実装
生成されるすべてのWebページについて、ISO-8859-1やUTF-8などの文字エンコーディングを使用し、指定してください。 エンコーディングが指定されていない場合、WebブラウザーはWebページで実際に使用されているエンコーディングを推測して、異なるエンコーディングを選択する可能性があります。 これにより、Webブラウザーが特定のシーケンスを特殊なものとして扱い、クライアントが巧妙なXSS攻撃にさらされる可能性があります。 エンコーディング/エスケープに関連するその他の緩和策については、CWE-116を参照してください。

ユーザーのセッションクッキーに対するXSS攻撃を緩和するために、セッションCookieを HttpOnly に設定してください。 HttpOnly 機能をサポートするブラウザー (最近のバージョンのFirefoxなど) では、この属性により document.cookie を使用する悪意のあるクライアントサイドスクリプトがユーザーのセッションCookieにアクセスするのを防ぐことができます。 これは完全な解決策ではありません。なぜなら、HttpOnly はすべてのブラウザーでサポートされているわけではないからです。 さらに重要なことに、XMLHTTPRequest やその他の強力なブラウザー技術は、HttpOnly フラグが設定されている Set-Cookie ヘッダーを含むHTTPヘッダーへの読み取りアクセスを提供します。

すべての入力を悪意のあるものと想定してください。 「既知の安全なものを受け入れる (accept known good)」入力検証戦略、つまり、仕様に厳密に準拠する入力の許可リスト (ホワイトリスト) を使用してください。 仕様に厳密に従わない入力は拒否するか、準拠するよう変換してください。 悪意のある、または不正な形式の入力を探すことだけに頼らないでください (すなわち、拒否リスト (ブラックリスト) に頼らないでください)。 ただし、拒否リストは潜在的な攻撃を検出したり、どの入力が非常に不正な形式であるため完全に拒否すべきかを判断したりするのに役立ちます。

入力検証を実行する際は、長さ、入力の種類、許容可能な値の全範囲、入力の欠落または過剰、構文、関連フィールド間の一貫性、およびビジネスルールへの準拠など、すべての潜在的に関連するプロパティを考慮してください。 ビジネスルールのロジックの例として、「boat」は英数字のみを含むため構文的には有効かもしれませんが、「red」や「blue」のような色を期待している場合は有効ではありません。

アプリケーション内の明確に定義されたインターフェースで入力検証を実行することを確認してください。 これにより、コンポーネントが再利用されたり、他の場所に移動されたりしても、アプリケーションを保護するのに役立ちます。

リクエスト

POST	http://127.0.0.1:39823/contacts/add
パラメーター	data[Contact][message]
攻撃	<scRipt>alert(1);</scRipt>
根拠	<scRipt>alert(1);</scRipt>

参考

- https://www.zaproxy.org/docs/alerts/40012/
- https://owasp.org/www-community/attacks/xss/
- https://cwe.mitre.org/data/definitions/79.html

3. 低

3-1　SameSite属性のないCookie

低

アラート ID	10054-1
リスク	低
確度	中
CWE	CWE-1275
WASC	WASC-13
リクエスト	2

SameSite 属性がないCookieが設定されました。このため、そのCookieは「クロスサイト」リクエストの結果として送信される可能性があります。SameSite属性は、クロスサイトリクエストフォージェリ、クロスサイトスクリプトインクルージョン、およびタイミング攻撃に対する効果的な対策です。

対策

すべてのCookieについて、SameSite属性を 'lax' または、理想的には 'strict' に設定してください。

リクエスト

GET http://127.0.0.1:39823/contacts/add	
パラメーター	CAKEPHP
根拠	Set-Cookie: CAKEPHP

POST http://127.0.0.1:39823/contacts/add	
パラメーター	CAKEPHP
根拠	Set-Cookie: CAKEPHP

参考

- https://www.zaproxy.org/docs/alerts/10054/
- https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

3. 低

3-2　X-Content-Type-Optionsヘッダーがありません　低

アラート ID	10021
リスク	低
確度	中
CWE	CWE-693
WASC	WASC-15
リクエスト	2

MIME推測防止ヘッダー X-Content-Type-Options が 'nosniff' に設定されていません。この設定により、ブラウザがContent-Typeヘッダーを無視してファイル内容から推測でMIMEタイプを決定する可能性があります。これは、攻撃者がアップロードしたファイルを意図しないコンテンツタイプ (JavaScript、HTMLなど) として実行させ、XSS攻撃を実行する手法に悪用される恐れがあります。現代のブラウザでも、この設定がない場合はMIME推測が実行される可能性があります。

対策

アプリケーション/Webサーバーが Content-Type ヘッダーを適切に設定し、すべてのWebページに対して X-Content-Type-Options ヘッダーに 'nosniff' を設定していることを確認してください。
可能であれば、エンドユーザーが MIME スニッフィングを一切実行しないか、Webアプリケーション/Webサーバーの指示に従って MIME スニッフィングを無効化できる、標準に準拠した最新のWebブラウザーを使用していることを確認してください。

リクエスト

GET http://127.0.0.1:39823/contacts/add	
パラメーター	x-content-type-options
その他の情報	この問題は、エラーページ（401、403、500 など）にも依然として該当します。これらのページもインジェクション攻撃の影響を受けることが多く、その場合ブラウザーが意図されたコンテンツタイプを無視して MIME スニッフィングを行うリスクが残るためです。 しきい値「高」では、このスキャンルールはクライアントエラーおよびサーバーエラーのレスポンスに対してアラートを発生させません。

POST http://127.0.0.1:39823/contacts/add	
パラメーター	x-content-type-options
その他の情報	この問題は、エラーページ（401、403、500 など）にも依然として該当します。これらのページもインジェクション攻撃の影響を受けることが多く、その場合ブラウザーが意図されたコンテンツタイプを無視して MIME スニッフィングを行うリスクが残るためです。 しきい値「高」では、このスキャンルールはクライアントエラーおよびサーバーエラーのレスポンスに対してアラートを発生させません。

参考

- https://www.zaproxy.org/docs/alerts/10021/
- https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
- https://owasp.org/www-community/Security_Headers

3. 低

3-3　サーバーが "X-Powered-By" HTTPレスポンスヘッダーフィールド経由で情報を漏洩

低

アラート ID	10037
リスク	低
確度	中
CWE	CWE-497
WASC	WASC-13
リクエスト	3

サーバーが1つ以上の "X-Powered-By" HTTPレスポンスヘッダーを介して情報を漏洩しています。

この情報にアクセスした攻撃者は、Webアプリケーションが依存している他のフレームワークやコンポーネントを特定し、それらのコンポーネントが抱える脆弱性を悪用できる可能性があります。

対策

Webサーバー、アプリケーションサーバー、ロードバランサーなどがX-Powered-Byヘッダーを抑制するように設定されていることを確認してください。

リクエスト

GET	http://127.0.0.1:39823/
根拠	X-Powered-By: PHP/8.4

GET	http://127.0.0.1:39823/contacts/add
根拠	X-Powered-By: PHP/8.4

POST	http://127.0.0.1:39823/contacts/add
根拠	X-Powered-By: PHP/8.4

参考

- https://www.zaproxy.org/docs/alerts/10037/
- https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
- https://www.troyhunt.com/shhh-dont-let-your-response-headers/

4. 情報

4-1　セッション管理レスポンスの特定

情報

アラート ID	10112
リスク	情報
確度	中
リクエスト	1

指定されたレスポンスにセッション管理トークンが含まれていることが識別されました。「追加情報」フィールドには、ヘッダーベースセッション管理方式で使用可能なヘッダートークンのセットが含まれています。このリクエストがセッション管理方式を「自動検出」に設定したコンテキスト内にある場合、このルールによって識別されたトークンを利用したセッション管理方式に変更されます。

対策

これは脆弱性ではなく情報提供のアラートであるため、修正すべき点はありません。

リクエスト

GET	http://127.0.0.1:39823/contacts/add
パラメーター	CAKEPHP
根拠	CAKEPHP
その他の情報	cookie:CAKEPHP

参考

- https://www.zaproxy.org/docs/alerts/10112/
- https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

4. 情報

4-2　ユーザーエージェントファザー (User Agent Fuzzer)　情報

アラート ID	10104
リスク	情報
確度	中
リクエスト	3

ファズされた (fuzzed) ユーザーエージェント (例: モバイルサイト、検索エンジンのクローラーとしてアクセス) に基づいて、レスポンスの違いをチェックします。レスポンスのステータスコードとレスポンスボディのハッシュコードを元のレスポンスと比較します。

リクエスト

GET	http://127.0.0.1:39823/contacts/add
パラメーター	ヘッダー : User-Agent
攻撃	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

POST	http://127.0.0.1:39823/contacts/add
パラメーター	ヘッダー : User-Agent
攻撃	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)

POST	http://127.0.0.1:39823/contacts/add
パラメーター	ヘッダー : User-Agent
攻撃	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

参考

- https://www.zaproxy.org/docs/alerts/10104/
- https://owasp.org/wstg